

Draft reply — OL enterprise IT / cybersecurity review of the Hilmar Tracker

Draft for Michael's review before sending. Addressed to the reviewer who prepared the assessment; the security-posture section can be shared with Carrie as-is. Replace [Reviewer] with the recipient's name. The full technical detail referenced below is in docs/ENTERPRISE-MODERNIZATION.md — attach or link it.

Hi [Reviewer],

Thank you for the thorough review — it was genuinely useful, and I want to start by saying we agree with its central finding. The assessment was fair, specific, and constructive, and it gives us a clear path to bring the Hilmar Daily Shipment Tracker fully in line with OL enterprise standards.

I've put together a detailed, costed, phased modernization plan (attached). Here is the short version, with the security points addressed directly, since I know that is the main concern.

On security — we agree, and here is the concrete fix

You correctly identified the **authentication model as the top risk**, and we are treating it as priority #1. You are right that locally cached mailbox tokens requiring periodic manual re-authentication are not an enterprise production pattern. To reassure you specifically on how we close this:

- We will move from **delegated, device-code authentication on a personal account** to a **dedicated Entra app registration** that runs as a proper service principal — no human identity in the loop.
- It will use **application permissions** (`Mail.Read`, `Mail.Send`) consented once by an OL tenant admin, and — critically — those permissions will be **scoped by an Application Access Policy to a single Hilmar service mailbox**. The app will be technically incapable of touching any other mailbox in the tenant. That access policy is the key least-privilege control, and we will verify it before go-live.
- The credential will be **workload identity federation** (preferred — no secret or certificate stored anywhere at all) or, as a fallback, a **certificate held in Azure Key Vault**. Either way, **no bearer token or secret ever sits on disk again**, and the `token-cache.json` file is retired entirely.
- The result is **fully unattended, enterprise-grade authentication** — no device-code prompts, no manual refreshes, no dependency on any one person's account, and a clean service-principal audit trail.

That single change resolves the most serious item on your list. The rest is hardening, and we agree with essentially all of it:

- **Secrets** move to **Azure Key Vault** — the local `secrets/` folder is eliminated.
- **Compute** moves off the Windows Cloud PC to **Azure Container Apps**; scheduling moves to an **Azure-native trigger** — no more Windows Task Scheduler, no always-on machine, no RDP administration.
- **Governance** moves to **centralized RBAC via Entra groups**, managed identities for service-to-service auth, and Azure Policy for compliance.

For context on data sensitivity: the tracker handles internal business shipment data and internal email correspondence — no customer PII, no financial account data. With the move to Key Vault, Blob Storage, and managed identities, everything is encrypted at rest and in transit and governed by OL RBAC by default.

Two adjustments we'd recommend — both to save cost, not to cut corners

There are exactly two places where we'd suggest a lighter target than the review proposed. Both keep the governance benefit while avoiding cost the workload doesn't justify:

1. **Data store — Azure Blob Storage rather than PostgreSQL / Azure SQL.** The tracker's "database" is a single 155–170 row dataset. A managed relational database adds real monthly cost and operational overhead for no functional benefit at that scale. **Blob Storage with versioning and soft-delete** delivers exactly what a relational DB would give us here — change history, an audit trail, recovery, managed retention, and RBAC-governed access — at a fraction of the cost. If a relational store is a hard OL standard, we'd suggest **Azure SQL serverless** (auto-pauses when idle) over provisioned PostgreSQL.
2. **Observability.** You asked whether **Datadog** would be the better move. Honest answer: for *this* workload, no. Datadog is excellent for broad infrastructure and APM monitoring across a fleet of services, but this is a single 15-minute-a-day batch job — Datadog would be both overkill and the most expensive option. It's also worth noting that Datadog, while it bills *through* Azure, still sends telemetry to a third-party SaaS, so it isn't "Azure-native" in the data-residency sense. Our recommendation, if we are moving off Sentry for standardization, is **Azure Monitor + Application Insights** — that one *is* genuinely Azure-native, keeps telemetry inside the OL tenant, is billed on the Azure invoice, and is cheaper. We'd only recommend Datadog if OL chooses to standardize on it across many projects.

With the recommended design, the **total Azure run cost for this workload is roughly \$15–45/month** — modest and mostly fixed. The full breakdown is in the attached plan.

One dependency to flag early

The authentication fix depends on an **OL tenant administrator** to create the app registration, grant admin consent, and apply the Application Access Policy. That is the long-pole item, so I'd like to start that request now, in parallel with everything else, so it doesn't hold up the timeline.

Approach and sequencing

We fully agree with reviewing each system individually, defining the OL enterprise patterns, and building a repeatable deployment model. We'd be glad for the Hilmar modernization to serve as the **pilot / reference implementation** for that standard — the attached plan is structured so it can.

We also agree with your sequencing: **sandbox first**, a **parallel-run** validation window against the current system, and **production cutover last**.

One reassurance on scope: this is an **infrastructure and authentication modernization, not an application rewrite**. The parts you assessed as sound — the parser, the QC self-heal framework, the accuracy gate, the reporting — are not changing. That keeps the effort contained and low-risk.

I've attached the full plan with the phased roadmap, cost detail, and architecture. Happy to walk through any of it with you and Carrie whenever works, and to adjust to whatever OL standards you land on.

Thanks again for the careful review — it genuinely helps.

Best, Michael Deitchman